

Network Attacks

NECKER

December 1, 2025

Contents

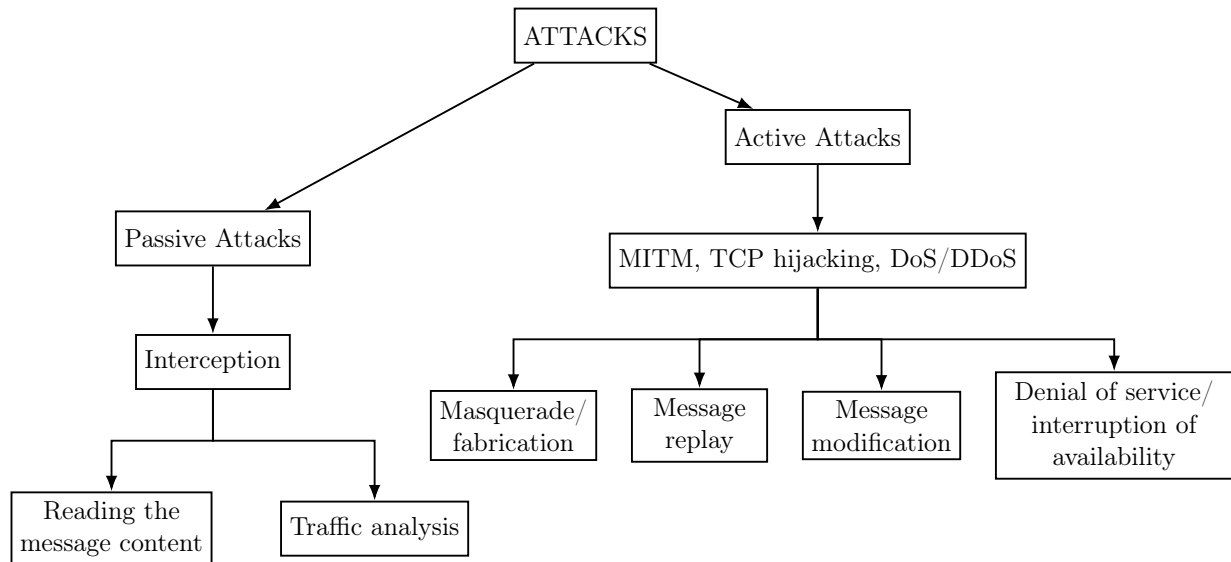
1	Classification of Network Attacks	2
2	Passive Attacks: Sniffing and Physical Interception	2
2.1	Sniffing (Passive Network Interception)	2
2.2	Physical Interception of the Transmission Medium	4
2.2.1	Interception via Electromagnetic (EM) Emissions	4
2.2.2	Interception on Fiber Optics	4
3	Active Manipulation and Deception Attacks (Spoofing and MITM)	5
3.1	Spoofing (Identity Falsification)	5
3.2	Man-in-the-Middle (MITM)	6
3.3	DNS Pharming (Malicious Redirection)	6
4	Denial of Service Attacks (DoS/DDoS)	6
4.1	Bandwidth and Protocol Saturation Attacks	7
4.2	Resource Exhaustion Attacks	7
4.3	DoS/DDoS Countermeasures	8
5	Advanced Attacks: TCP Hijacking	9
5.1	TCP Hijacking – Mitnick’s Attack (1994)	9

1 Classification of Network Attacks

Main Taxonomic Scheme

The landscape of cyber attacks is divided into two main macro-categories: Passive attacks (interception) and Active attacks (modification or generation of traffic).

Network Attacks Taxonomy



2 Passive Attacks: Sniffing and Physical Interception

2.1 Sniffing (Passive Network Interception)

Definition and Operation

Sniffing is the technique of capturing and analyzing data packets traversing a network segment (therefore applicable only if one is on the same network). It is defined as **passive interception** because the attacker merely **listens** to the existing traffic without modifying it or generating new packets to deceive the systems (unlike Spoofing).

- The attacker uses a **sniffer** software (or packet analyzer) that puts their network interface card (NIC) into **promiscuous mode**.
- In *promiscuous mode*, the card receives and processes **all packets** passing on the network segment, not just those destined for its own MAC address.
- The attack is most effective on networks utilizing **Hubs** (which forward all packets to everyone), but on modern **Switch**-based networks, it must be combined with an active technique (such as ARP Spoofing) to redirect the traffic.

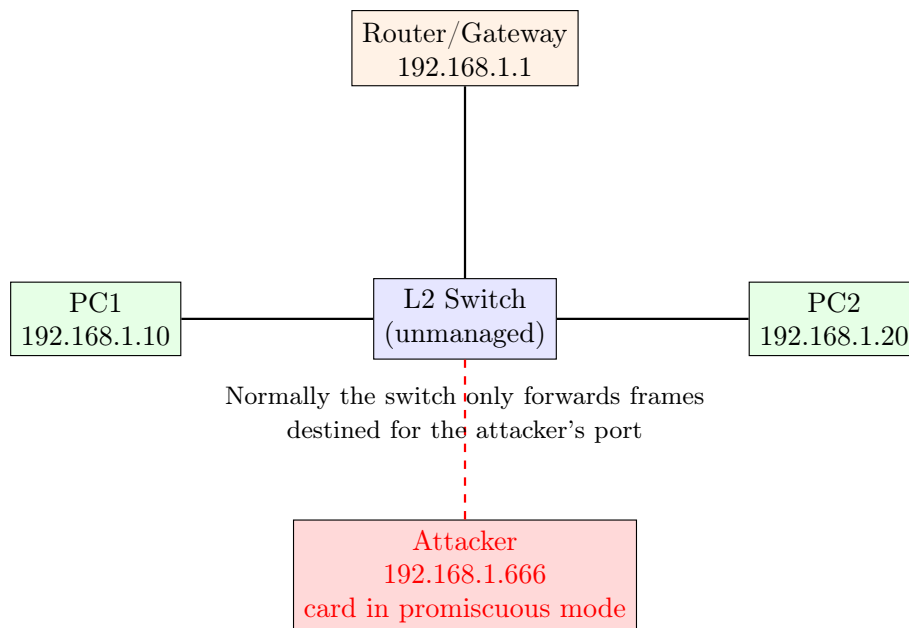
WARNING: generally, however, the data passing through is never in cleartext but is encrypted (if the network is properly configured).

Objectives

The primary goal of Sniffing is gathering information:

1. **Credential Capture:** Intercepting usernames and passwords transmitted in cleartext (over unencrypted protocols such as HTTP, FTP, Telnet).
2. **Protocol Analysis:** Studying network behavior, the protocols in use, and identifying the IP and MAC addresses of the hosts.
3. **Data Interception:** Acquiring the content of communications, documents, or sensitive information.

Example: Sniffing on an Unmanaged Network



Techniques and Tools for Sniffing on Switches

Techniques to Enable Sniffing on Switches

Technique	Description
ARP Poisoning	The most widely used. Poisons the victims' ARP cache → the attacker becomes a Man-in-the-Middle.
MAC Flooding	Fills the CAM table with fake MAC addresses → switch enters fail-open mode (behaves like a hub).
Port Mirroring (SPAN/RSPAN)	Legitimate administrative configuration that duplicates traffic to a monitoring port.
Physical Hub	All devices see all traffic (practically extinct).
Network TAP (used by police)	Passive hardware device that physically duplicates the flow.

After the attack: all traffic between the victim and the gateway passes through the attacker.

Packet Analysis Tools

Tool	Notes
Wireshark	Most powerful GUI in the world, advanced display filters
tcpdump / tshark	Ideal on headless servers and scripts
ettercap	Specialized in ARP spoofing + integrated sniffing
BetterCAP	Modern framework (also supports Wi-Fi, BLE, HTTP/2, etc.)
arp spoof (dsniff)	Classic, still functional
cain (Windows)	Historical all-in-one on Windows

2.2 Physical Interception of the Transmission Medium

Passive interception is not limited to software-level packet analysis, but also exploits the physical properties of cables and transmissions.

2.2.1 Interception via Electromagnetic (EM) Emissions

All electronic devices and unshielded network cables, or cables with insufficient shielding (*UTP cables*), emit residual electromagnetic radiation carrying the data signal.

- **Technique:** The attacker uses high-sensitivity receivers and directional antennas to capture these emissions from a distance.
- **Objective:** Decoding the EM signal to reconstruct the data stream transmitted through the cable (a non-invasive method).
- **Defense:** Implementation of the **TEMPEST** methodology (Telecommunications Electronics Material Protected from Emanating Spurious Transmissions), prescribing rigorous shielding standards (*STP cables*) and Faraday cages to prevent the leakage of emissions.

2.2.2 Interception on Fiber Optics

Fiber optic transmissions (which use light to carry data) are generally considered more secure because they do not emit electromagnetic radiation, but they can still be passively intercepted if the cable is accessed.

- **Technique:** A non-destructive attack such as **Micro-bending** or the use of an **optical splitter** is utilized.
- **Micro-bending:** By slightly and precisely bending the fiber cable (without breaking it), it is possible to deflect a minimal amount of light (a few photons) carrying the signal. This deflected signal is then captured and amplified by a high-sensitivity optical receiver.
- **Advantage:** The attack is **passive** and **stealthy** (hidden), because the small loss of light is not enough to trigger signal power monitoring alarms on the network.

3 Active Manipulation and Deception Attacks (Spoofing and MITM)

3.1 Spoofing (Identity Falsification)

Definition and Purpose

Spoofing is a category of cyber attacks in which an aggressor **falsifies their identity**, pretending to be a trusted and legitimate entity, device, or source. The primary purpose is deception, aimed at bypassing security controls, gaining unauthorized access, or stealing sensitive data.

- Unlike Sniffing (passive), Spoofing is an **active** attack, since the attacker generates and sends modified data to deceive the victim or the network.
- The effectiveness of Spoofing lies in exploiting the **implicit trust** in network protocols or **human trust** (Social Engineering).

Common Types of Spoofing

Spoofing manifests in different forms, depending on the communication layer being falsified:

ARP Spoofing (Address Resolution Protocol)

- **What it Falsifies:** Associates a fake **MAC** address (the attacker's) with a legitimate **IP** address (for example, that of the router or another host) within a local area network (LAN).
- **Effect:** Deceives other devices on the network into believing that the correct path for that IP goes through the attacker's machine. This enables complete interception of traffic (**Man-in-the-Middle**).
- **How:** Since devices on the same network locate each other through the **MAC** address and since each PC has a **stateless** table (meaning it does not remember if information changes over time), a single malicious **ARP** request is enough to change the **MAC** associated with an **IP**.
- **Countermeasure:** Wherever possible, **static ARPs** are implemented, meaning the **ARPs** are manually entered by the system administrator and cannot be automatically updated by dynamic ARP traffic.

IP Spoofing (Internet Protocol)

- **What it Falsifies:** Replaces the source IP address in the header of a network packet with a **fake IP address**.
- **Effect:** Hides the attacker's real identity and can be used to bypass network filters that authorize only specific IPs; it is frequently used in **Distributed Denial of Service (DDoS)** attacks to mask bots.
- **How:** The IP contained in the packet **header** is modified.

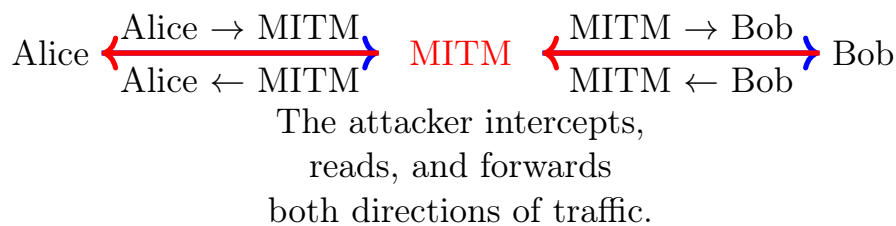
Email Spoofing

- **What it Falsifies:** Modifies the header of an email message to display a different and apparently legitimate **sender** address.
- **Effect:** It is the foundation for **Phishing** or **Spear-Phishing** campaigns, aimed at convincing the recipient to provide credentials or transfer funds.
- **How:** The aggressor uses a software or an SMTP server configured to specify an email address in the From: field (Sender) different from their real address.

3.2 Man-in-the-Middle (MITM)

The **Man-in-the-Middle (MITM)** attack is a form of active interception in which the aggressor secretly interposes themselves between two communicating parties, intercepting and potentially modifying all messages passing between them without the parties' knowledge.

- **Mechanism:** The attacker acts as a relay, making Alice believe she is communicating directly with Bob, and Bob believe he is communicating directly with Alice.
- **Purpose:** Intercepting credentials, modifying transactions, or stealing cryptographic information before it is protected.
- **Common implementation:** On a local network, it is often achieved via **ARP Spoofing** or **DNS Spoofing** to redirect traffic.



3.3 DNS Pharming (Malicious Redirection)

Pharming is a fraud technique aimed at **redirecting** users from a legitimate website to a fake site without their knowledge, even if they type the correct URL. Spoofing is used to falsify the responses of the name resolution service (DNS).

- **Mechanism:** The domain name (URL) resolution process into the server's IP address is manipulated.
- **Types of Malicious Redirection:**
 1. **Hosts File Modification:** The attacker infects the victim's local machine and modifies the **hosts** file, forcing the browser to resolve the legitimate domain name (e.g., **bank.com**) to a malicious IP.
 2. **DNS Cache Poisoning:** The attacker injects fake data into the DNS server's cache, making the server believe that the IP of the target domain is that of the fake site controlled by the aggressor. All users querying that DNS server will be redirected (to do this, the attacker sends many packets with the malicious IP linked to the domain, trying to convince the **DNS** that it is a legitimate IP).
 3. **Compromised Router:** The attacker compromises the network router and modifies its settings to use a malicious DNS server.

4 Denial of Service Attacks (DoS/DDoS)

Denial of Service and **Distributed Denial of Service (DDoS)** attacks aim to render a service or network resource unavailable by overwhelming the victim system with an excessive volume of traffic generated from a single source or multiple distributed sources (often a *botnet*). The goal is to consume vital resources such as bandwidth, CPU, memory, or connection tables.

4.1 Bandwidth and Protocol Saturation Attacks

- **Ping of Death**

- **Technique:** Sending an **ICMP Echo Request** (ping) packet with a size exceeding the maximum allowed for the IP protocol (**greater than 65535 bytes**).
- **Effect:** When older operating systems attempted to reassemble the fragmented packet, the buffer overflow caused the system to crash or reboot. (Note: this attack is widely **patched** in modern operating systems but still possible on **Windows 7**).
- **How:** The **OS** allocated a buffer in memory to reassemble the packet; however, it could overflow, and immediately following it were structures crucial to the operation of the operating system itself.

- **Smurf**

- **Technique:** The attacker sends an ICMP Echo Request (ping) packet with the source IP address **falsified** (*spoofed*) with the victim's IP address. This packet is sent to the **broadcast** address of an intermediate network.
- **Effect:** All hosts on that intermediate network simultaneously respond to the victim, massively amplifying traffic. (Attacks mitigated by blocking broadcast forwarding on routers).

- **LAND (Local Area Network Denial)**

- **Technique:** Sending a **TCP SYN** packet where the source IP address (**src IP**) and the destination IP address (**dst IP**) are **equal** (the victim's address).
- **Effect:** The victim system enters an infinite loop trying to respond to its own address, consuming resources and causing the operating system or service to crash. (Attack widely **patched**).

- **SYN Flooding**

- **Technique:** The attacker sends a massive sequence of **TCP SYN** packets, often with **falsified** (*spoofed*) source IP addresses.
- **Effect:** For each received SYN, the victim server allocates resources in a structure called the **backlog**, waiting for the **ACK** packet to complete the three-way handshake (SYN, SYN-ACK, ACK). Since the attacker never sends the ACK (or does not receive the SYN-ACK due to the spoofed IP), the server's backlog fills up rapidly, preventing it from accepting new legitimate connections.

4.2 Resource Exhaustion Attacks

File System Saturation (Attack on Firewalls)

These attacks do not aim to saturate network bandwidth or the connection table, but to exhaust the storage or memory resources of the defense device (such as a firewall or a router) or the operating system, causing it to freeze or crash.

- **Objective:** Saturating the disk space or log partition of the firewall, making it impossible to write new security events.
- **Technique:** The attacker sends an extremely high volume of packets that the firewall must **deny** and **record** (log).
 - Often, **UDP** or **ICMP** packets destined for non-existent ports or addresses are used.

- The firewall, following its security policy, generates an **error message** (e.g., ICMP Destination Unreachable) for each denied packet and simultaneously **writes a log** of the event.
- If the packet generation rate exceeds the firewall’s logging capacity, the temporary memory (buffer) for logs fills up, and in some systems, the logging file system can saturate rapidly.
- **Effect:** When the firewall’s file system is full, it may cease to function correctly, reboot, or stop logging, preventing administrators from detecting other attacks.

4.3 DoS/DDoS Countermeasures

- **SYN Cookies:** An effective mechanism against SYN Flooding. The server responds to the SYN with a SYN-ACK containing a **cryptographic cookie** instead of immediately allocating space in the backlog. Resource allocation occurs only if and when it receives a final valid ACK containing the cookie, proving it is a legitimate connection (the cookie contains all the necessary information to avoid allocating resources prematurely).
- **Egress Filtering:** Implementation of outbound filters on networks (e.g., at ISPs) to prevent sending packets with source IP addresses not belonging to the local network, thereby mitigating the use of IP Spoofing in attacks.
- **Rate Limiting:** Limiting the number of requests per protocol (e.g., TCP SYN) accepted from a single IP address or from a specific source in a given time interval.
- **Firewalls:** Used to limit incoming malicious traffic.

5 Advanced Attacks: TCP Hijacking

5.1 TCP Hijacking – Mitnick’s Attack (1994)

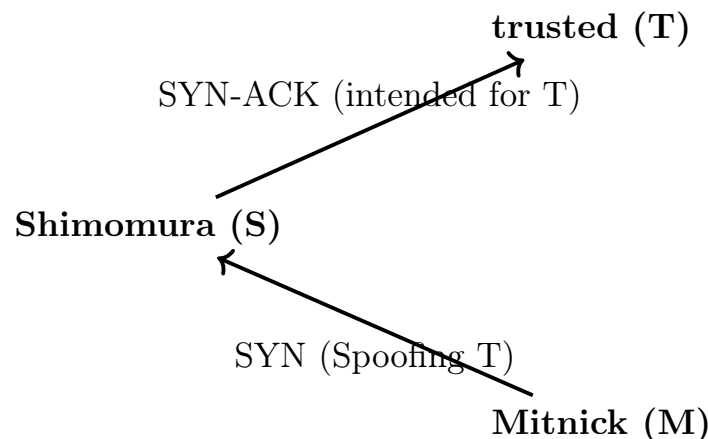
TCP Hijacking is the act of taking control of an established and authenticated TCP session between two hosts. Kevin Mitnick’s attack against Tsutomu Shimomura in 1994 is the most famous example of **IP Spoofing** combined with **Sequence Number Prediction** to hijack a trusted session.

Context and Objective

The attack relied on a **trust relationship** (*trust relationship*) between two of Shimomura’s machines:

- **Shimomura (S)**: The main target computer Mitnick wanted to access (**rsh Server**).
- **Trusted Host (T)**: A trusted computer that could connect to S and execute commands (e.g., **rsh**: Remote Shell) without requiring a password (**trusted Client**).

Mitnick’s (M) goal was to impersonate the trusted host (T) to establish an **rsh** session with S and obtain root privileges (to then install a backdoor on S and operate from there).



NOTE: The historical attack exploited the *predictability* of the Initial Sequence Number (ISN) generated by the SunOS operating system of computer S.

Detailed Steps of the Attack

The attack was a masterpiece of social and technical engineering, composed of five crucial phases:

1. **Information Gathering (with commands like `finger @S` and `showmount -e`):** Mitnick used standard network commands to gather data on system S, including active users (to attack when no one was around) and the trusted system T.
2. **Disabling the Trusted Host (T):** The attacker floods host T with **SYN Flood** packets to saturate its connection table (the *backlog*) and make it temporarily incapable of responding to new requests. This step is crucial so that host T does not send a **RST** (reset) packet when it receives the **SYN-ACK** intended for it; indeed, if T received an anomalous **SYN-ACK**, it would send a **RST** response to abort the connection.

3. **Sequence Number Prediction (ISN):** Mitnick sent SYN packets to S and analyzed the corresponding SYN-ACKs to understand the **pattern** of Initial Sequence Number (ISN) generation by S's operating system. Once the pattern was identified (at the time it was predictable), he was able to calculate the ISN S would use in the next response.
4. **Session Injection (IP Spoofing):** Mitnick sends S a **SYN** packet with the source IP address **falsified** as if it were the trusted host T (IP Spoofing).
 - S responds by sending a **SYN-ACK** packet to the spoofed IP address (T).
 - Since T is inactive (due to the SYN flood), it does not receive or process the **SYN-ACK** packet.
5. **Completing the Handshake and Command:** Mitnick sends an **ACK** packet to S using the spoofed IP of T and specifying the predicted Sequence Number ($ISN + 1$) to complete the fictitious three-way TCP handshake. At this point, S believes a legitimate session has been established with T. The attacker can then inject commands (such as **rsh** to create a backdoor) that S executes with the privileges of the trusted host.

Current Countermeasures

Mitnick's attack highlighted a severe weakness in the TCP protocol. Today, the attack is nearly **impossible** to replicate in this manner because:

- Modern operating systems robustly **randomize** Initial Sequence Numbers (ISN), preventing prediction.
- Trust relationships based solely on the IP address (such as **rsh**) have been largely abandoned in favor of more secure authentication mechanisms (such as SSH).